

Fancy Bear CTI Report

Joseph J. Patnoe

Department of Cyber, Intelligence, and Information Operations, The University of Arizona

CYBV 435: Cyber Threat Intelligence

Professor Ryan Roberts

10 October 2025

Table of Contents

Contents

Overview of APT28.....	3
Nation State Sponsorship and Allegiance.....	4
Targeting, Motives, and Goals	5
Target Industries and Geographies	5
Motives and Goals	5
Tactics, Techniques, and Tools	5
Initial Access	5
Execution, Persistence, Privilege Escalation, and Evasion.....	6
Command and Control (C2) and Exfiltration	6
APT28 Kill Chain.....	7
Example Indicator of Compromise	7
References	8

Overview of APT28

Fancy Bear—also tracked as APT28, Sofacy, Sednit, STRONTIUM, Pawn Storm, TG-4127, and Tsar Team—has conducted aggressive, long-running espionage and influence operations since at least the mid-2000s (Pols, 2017). Reporting describes the group as prolific and dynamic, with a multi-stage malware ecosystem and the operational capacity to run multiple, large-scale campaigns (CrowdStrike, 2019; Pols, 2017). Public narratives connect APT28 to high-visibility compromises and information operations, including intrusions against Western political and military targets, with activity often aligned to Russian strategic interests (CrowdStrike, 2019; NJCCIC, n.d.; Pols, 2017).

A persistent theme across public reporting is that APT28's operations are not always concerned for stealth; campaigns have been described as “brazen,” where public exposure has strategic influence for their goals via media effects and timed information releases (Pols, 2017). The group's capability spans conventional endpoints and mobile platforms, and includes custom implants (XAgent/CHOPSTICK) and tunneling utilities (XTunnel), supported by credential-harvesting and phishing infrastructure (CrowdStrike, 2019; NCSC, 2018).

Nation State Sponsorship and Allegiance

APT28 has been consistently attributed to the Russian Federation's Main Intelligence Directorate, known as the GRU. The GRU serves as Russia's military intelligence agency, tasked with both strategic and tactical information gathering in support of the Russian Armed Forces. According to assessments by CrowdStrike, the U.S. Department of Homeland Security, and the New Jersey Cybersecurity and Communications Integration Cell (NJCCIC), APT28 is believed to operate under the GRU's Unit 26165, which has been linked through technical evidence and geopolitical analysis to cyber operations supporting Russian military and political goals (NJCCIC, n.d.; Pols, 2017).

APT28's alignment with GRU objectives is reinforced by strong circumstantial and forensic indicators. Malware compiled in Russian-language environments, timestamps consistent with Moscow Standard Time (UTC +3), and the consistent targeting of NATO, U.S., and European defense entities suggest state direction and logistical support. The actor's operations often occur during Russian business hours, mirroring other GRU units' activity patterns (CrowdStrike, 2019). These temporal correlations, combined with shared infrastructure and developmental overlap between APT28 and other Russian threat clusters (APT29 and Sandworm), highlight an interconnected system of state-sponsored cyber units operating under centralized structures.

Targeting, Motives, and Goals

Target Industries and Geographies

APT28 consistently targets government and defense organizations, political parties, media, energy and other critical infrastructure. Aerospace/aviation, research, and technology sectors across NATO are affected as well. Allied countries including the United States, Ukraine, Germany, France, Poland, the Baltic states, and the United Kingdom are all government targets (CrowdStrike, 2019; NJCCIC, n.d.).

Motives and Goals

Historically, APT28's objectives centered on intelligence collection that benefits the Russian state. However, reporting also documents the expansion into covert influence ("active measures") designed to shape public opinion and political outcomes via strategic release of stolen data (Pols, 2017). Their campaigns seek to undermine adversary capabilities, create diplomatic friction, and advance Russia's military-political interests (CrowdStrike, 2019; NJCCIC, n.d.; Pols, 2017).

Tactics, Techniques, and Tools

Initial Access

- **Spear-phishing & Credential Harvesting:** The group uses tailored phishing emails and domain spoofing to mimic webmail and employee login portals. This is used to harvest credentials and deliver malicious documents/links (Crowdstrike, 2019).

- **Watering Hole Compromises:** Legitimate websites that are frequented by targets are compromised to deliver exploits (Pols, 2017).
- **Network Device Exploitation:** APT28 has abused weak/default SNMPv2 community strings and exploited Cisco CVE-2017-6742 to globally access routers, enabling remote recon and malware deployment (NCSC, 2023).

Execution, Persistence, Privilege Escalation, and Evasion

- **Custom Implants:** XAgent/CHOPSTICK is a signature second-stage tool, frequently paired with XTunnel or other droppers (NCSC, 2018).
- **Living off the land:** Using legitimate admin tools to blend in target environments with normal activity and reduce suspicion.
- **Multi-Stage Ecosystem:** First stage implants limit exposure of high-value payloads. Tunnelling and VPN components may be used to bring attacker-controlled systems into the victim network (Pols, 2017).
- **Credential Reuse:** Stolen credentials enable APT28 to pivot to high-value internal systems (Pols, 2017).

Command and Control (C2) and Exfiltration

- **Encrypted C2:** Recent XAgent variants use TLS/SSL to protect C2 traffic (NCSC, 2018).
- **Flexible Hosting:** Use of VPS, compromised infrastructure, public cloud services, and mail servers for distribution and exfiltration (NJCCIC)
- **Synchronous Operation:** Parallel, multi-region campaigns show mature command structures and resource allocation (CrowdStrike, 2019).

APT28 Kill Chain

1. **Reconnaissance** – Research targets to craft believable lures; identify high-value systems and operators.
2. **Weaponization** – Spoofed domains, phishing kits, malicious links and documents are prepared for delivery, staging first-stage infrastructure.
3. **Delivery** – Spear-phishing emails and watering-hole attacks deliver links and document payloads (Pols, 2017).
4. **Exploitation** – Client exploits and credential-based access establish footholds for APT28 (NCSC, 2023).
5. **Installation** – Deployment of first-stage beacons, placement of XAgent and tunnelling tools such as XTunnel (CrowdStrike, 2019).
6. **Command & Control** – Using TLS/SSL for encrypted communications to resilient C2 infrastructure (NCSC, 2018).
7. **Actions on Objectives** – Data staging and exfiltration, credential harvesting, and influence on activities when aligned with operational goals (NJCCIC).

Example Indicator of Compromise

C2 IP 139.5.177.205 is associated with XAgent C2 infrastructure. Pairing known indicators with domain-based detection for associated sites like malaytravelgroup.com can help improve fidelity (NCSC, 2018).

References

APT28 exploits known vulnerability to carry out reconnaissance and deploy malware on Cisco routers | cisa. National Cyber Security Centre. (2023, April 18).

<https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-108>

Editorial Team. (2019, February 12). *Fancy bear hackers (APT28): Targets & methods*.

CrowdStrike. <https://www.crowdstrike.com/en-us/blog/who-is-fancy-bear/>

Indicators of compromise for malware used by APT28. NCSC. (2018, October 4).

<https://www.ncsc.gov.uk/news/indicators-of-compromise-for-malware-used-by-apt28>

Pols, P. (2017). *MODELING FANCY BEAR CYBER ATTACKS Designing a Unified Kill Chain for analyzing, comparing and defending against cyber attacks* (thesis).

Russia - APT28. New Jersey Cybersecurity & Communications Integration Cell. (n.d.).

<https://www.cyber.nj.gov/threat-landscape/nation-state-threat-analysis-reports/russia-cyber-threat-operations/russia-apt28>